Plano de resposta de riscos

NCCOMP6 – TennisHunt

Data: 05/11/2026

Versão: 1.2

Bruno Ribeiro

Guilherme Costa

Isadora Teixeira

Kauan Rocha

FECAP: Fundação de Comércio Álvares Penteado
São Paulo – São Paulo
2026

INTRODUÇÃO

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos identificados no projeto TennisHunt. O objetivo é aumentar as oportunidades (riscos positivos) e reduzir ou eliminar as ameaças (riscos negativos) aos objetivos do projeto. Este plano deve ser utilizado e atualizado continuamente pela equipe do projeto.

1 TABELA DE RESPOSTAS AOS RISCOS

ID do Risco	Nível do Risco	Estratégia de Resposta	Ações Específicas Planejadas	Responsável	Prazo	Status
A01	ALTO	Centralização	Implementar controles de acesso baseados em papéis (RBAC) ou atributos (ABAC) no lado do servidor, garantir que o usuário logado possui o ID correto e restringir tráfego de saída para mitigar SSRF.	Kauan	A definir	Em andamento
A02	Muito Alto	Automação de infraestrutura	Garantir que ambientes sigam o mesmo padrão seguro, desativar contas padrão, páginas de teste, recursos não utilizados e listagens de diretórios.	Bruno	A definir	Em andamento
A03	Alto	Visibilidade de dependências	Gerar e manter um SBOM, integrar ferramentas de SCA (Snyk, Trivy, Dependabot) no CI/CD para bloquear builds vulneráveis e fixar versões por hash e exigir assinatura criptográfica.	Guilherme	A definir	Em andamento
A04	Alto	Criptografia forte	Obrigar o uso de TLS 1.3/1.2, desativar cifras fracas, cifrar dados sensíveis com AES-256, usar Argon2/bcrypt para senhas e isolar chaves em KMS/Vault.	Isadora	A definir	Em andamento

ID do Risco	Nível do Risco	Estratégia de Resposta	Ações Específicas Planejadas	Responsável	Prazo	Status
A05	Alto	Separação entre dados e comandos	Utilizar Prepared Statements ou ORMs seguros, aplicar validação rigorosa de entrada (allowlists) e codificação de saída sensível ao contexto.	Guilherme	A definir	Em andamento
A06	Moderado	Segurança na arquitetura	Realizar modelagem de ameaças (STRIDE) nas fases iniciais e estabelecer padrões de design seguros antes da implementação.	Bruno	A definir	Em andamento
A07	Moderado	Autenticação multifator (MFA)	Exigir MFA resistente a phishing (FIDO2/TOTP), implementar rate limiting em logins e recuperação de senha, e garantir alta entropia em sessões.	Isadora	A definir	Em andamento
A08	Moderado	Desserialização segura	Evitar desserialização binária de dados não confiáveis, priorizar JSON com validação de esquema e proteger servidores de CI/CD.	Isadora	A definir	Em andamento
A09	Moderado	Observabilidade em tempo real	Registrar eventos críticos de forma centralizada, configurar alertas no SIEM/SOC e garantir logs imutáveis por no mínimo 90 dias.	Kauan	A definir	Em andamento
A10	Moderado	Tratamento de erros robusto	Capturar exceções localmente sem expor dados internos ou stack traces, substituindo-os por códigos de erro genéricos.	Guilherme	A definir	Em andamento

Detalhamento das Estratégias de Resposta

Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** Mudar o plano do projeto para eliminar a ameaça por completo. Significa não realizar a atividade que contém o risco.
  Exemplo: Substituir uma tecnologia nova e arriscada por uma já dominada pela equipe.

- **Transferir:** Repassar o impacto negativo do risco (e a responsabilidade pela resposta) para um terceiro. Não elimina o risco, apenas o transfere.
  Exemplo: Contratar um seguro, usar garantias ou terceirizar um serviço complexo para uma empresa especializada.

- **Mitigar:** Reduzir a probabilidade de ocorrência do risco e/ou seu impacto no projeto a um nível aceitável.
  Exemplo: Realizar mais testes para reduzir a chance de bugs críticos em produção; criar protótipos para validar requisitos complexos.

- **Aceitar:** Nenhuma ação proativa é tomada para alterar o plano do projeto.
  Aceitação Ativa: Criar uma reserva de contingência (tempo, dinheiro) para lidar com o risco caso ele ocorra.
  Aceitação Passiva: Não fazer nada e lidar com as consequências se o risco se materializar (geralmente para riscos de baixa prioridade).

Estratégias para Oportunidades (Riscos Positivos)

- **Explorar:** Tomar ações para garantir que a oportunidade se concretize.
  Exemplo: Alocar os melhores recursos para uma tarefa que pode terminar antes do prazo.

- **Melhorar (ou Realçar):** Aumentar a probabilidade de ocorrência da oportunidade e/ou seu impacto positivo.
  Exemplo: Investir em treinamento para a equipe sobre uma nova ferramenta que pode aumentar a produtividade.

- **Compartilhar:** Alocar a responsabilidade da oportunidade a um terceiro que esteja mais apto a aproveitá-la em benefício do projeto.
  Exemplo: Formar uma joint venture ou parceria para desenvolver um novo recurso.

- **Aceitar:** Não buscar ativamente a oportunidade, mas aproveitá-la se ela acontecer.
  Exemplo: Saber que um fornecedor pode oferecer um desconto, mas não tomar ações para garantir isso, apenas aproveitá-lo se for oferecido.

Monitoramento e Revisão

Este plano será revisado a cada duas semanas nas reuniões de status do projeto. O campo "Status"será atualizado para refletir o progresso das ações planejadas (Ex: Não Iniciado, Em Andamento, Concluído, Cancelado). Novos riscos podem ser adicionados e riscos existentes podem ser reavaliados conforme o projeto avança.